

법 제 29 조(안전조치의무)

개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

령 제 30 조(개인정보의 안전성 확보 조치)

① 개인정보처리자는 법 제 29 조에 따라 다음 각 호의 안전성 확보 조치를 해야 한다.

1. 다음 각 목의 내용을 포함하는 내부 관리계획의 수립·시행 및 점검
 - 가. 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항
 - 나. 개인정보 보호책임자의 지정 등 개인정보 보호 조직의 구성·운영에 관한 사항
 - 다. 본 시행령을 이행하기 위하여 필요한 세부 사항
2. 개인정보에 대한 접근 권한을 제한하기 위한 다음 각 목의 조치
 - 가. 개인정보처리시스템에 대한 접근 권한의 부여·변경·말소 등에 관한 기준의 수립·시행
 - 나. 정당한 권한을 가진 자에 의한 접근인지를 확인하기 위해 필요한 인증수단 적용 기준의 설정 및 운영
3. 개인정보에 대한 접근을 통제하기 위한 다음 각 목의 조치
 - 가. 개인정보처리시스템에 대한 침입을 탐지하고 차단하기 위하여 필요한 조치
 - 나. 개인정보처리시스템에 접속하는 개인정보취급자의 컴퓨터 등에 대한 인터넷망의 차단.
4. 개인정보를 안전하게 저장·전송하는데 필요한 다음 각 목의 조치
 - 가. 비밀번호의 일방향 암호화 저장 등 인증정보의 암호화 저장 또는 이에 상응하는 조치
 - 나. 주민등록번호 등 보호위원회가 정하여 고시하는 정보의 암호화 저장 또는 이에 상응하는 조치
 - 다. 정보통신망을 통하여 정보주체의 개인정보 또는 인증정보를 송신·수신하는 경우 해당 정보의 암호화 또는 이에 상응하는 조치
5. 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조

방지를 위한 다음 각 목의 조치

가. 개인정보처리시스템에 접속한 자의 접속일시, 처리내역 등 접속기록의 저장·점검 및 이의 확인·감독

나. 개인정보처리시스템에 대한 접속기록의 안전한 보관

6. 악성프로그램의 침투 여부를 항시 점검·치료할 수 있도록 하는 등의 기능이 포함된 프로그램의 설치·운영과 주기적 갱신·점검 조치

7. 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금장치의 설치 등 물리적 조치

③ 제 1 항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다.

령 제 30 조의 2(공공시스템 운영기관 등의 개인정보 안전성 확보 조치 등)

① 보호위원회가 고시하는 기준에 해당하는 개인정보처리시스템(이하 “공공시스템”이라 한다)을 운영하는 공공기관(이하 “공공시스템운영기관”이라 한다)은 법 제 29 조에 따라 이 영 제 30 조의 안전성 확보 조치 외에 다음 각 호의 조치를 추가로 해야 한다.

1. 제 30 조제 1 항제 1 호에 따른 내부 관리계획에 공공시스템별로 작성한 안전성 확보 조치를 포함할 것
2. 접근 권한의 안전한 관리를 위해 필요한 조치
3. 공공시스템 접속기록의 저장·분석·점검·관리 등의 조치

② 공공시스템운영기관 및 공공시스템이용기관은 정당한 권한 없이 또는 허용된 권한을 초과하여 개인정보에 접근한 사실이 확인되는 경우에는 지체 없이 정보주체에게 해당 사실과 피해 예방 등을 위해 필요한 사항을 통지해야 한다.

개인정보의 안전성 확보조치 기준

제 2 조(정의)

- **내부망:** 물리적으로 접속 구간이 한정되어 인터넷 등 외부망과 연결되지 않은 네트워크를 의미한다.
- **접근통제:** 허가된 인가자만 정보자산에 접근할 수 있도록 하는 것을 말한다.

- **접속기록:** 개인정보취급자 등이 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 개인정보취급자 등의 계정, 접속일시, 접속자 정보, 수행업무 등을 전자적으로 기록한 것을 말한다.

제 4 조(내부 관리계획의 수립·시행)

- **포함사항:** 개인정보 보호책임자는 다음 각 호의 사항을 포함하는 내부 관리계획을 수립하고, 이를 개인정보 보호책임자와 개인정보취급자에게 알려야 한다.
 1. 개인정보 보호책임자의 지정 등 개인정보 보호 조직의 구성·운영에 관한 사항
 2. 개인정보취급자의 역할 및 책임에 관한 사항
 3. 개인정보의 안전성 확보에 필요한 조치에 관한 사항 등

법 제 30 조(개인정보 처리방침의 수립 및 공개)

① 처리방침 필수 포함 사항

개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다.

1. 개인정보의 처리 목적
2. 개인정보의 처리 및 보유 기간
3. 개인정보의 제 3 자 제공에 관한 사항(해당되는 경우에만 정한다)
3 의 2. 개인정보의 파기절차 및 파기방법
3 의 3. 민감정보의 공개 가능성 및 비공개를 선택하는 방법(해당되는 경우에만 정한다)
4. 개인정보처리의 위탁에 관한 사항(해당되는 경우에만 정한다)
4 의 2. 가명정보의 처리 등에 관한 사항(해당되는 경우에만 정한다)
5. 정보주체와 법정대리인의 권리·의무 및 그 행사방법에 관한 사항
6. 개인정보 보호책임자의 성명 또는 개인정보 보호업무 및 관련 고충사항을 처리하는 부서의 명칭과 전화번호 등 연락처
7. 인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치·운영 및 그 거부에 관한 사항(해당하는 경우에만 정한다)
8. 그 밖에 개인정보의 처리에 관하여 대통령령으로 정한 사항

령 제 31 조(개인정보 처리방침의 내용 및 공개방법 등)

① 법 제 30 조제 1 항제 8 호에서 "대통령령으로 정한 사항"이란 다음 각 호의 사항을 말한다.

1. 처리하는 개인정보의 항목
2. 개인정보를 국외로 이전하는 경우 국외 이전의 근거와 같은 조 제 2 항 각 호의 사항
3. 시행령 제 30 조에 따른 개인정보의 안전성 확보 조치에 관한 사항
4. 국외에서 국내 정보주체의 개인정보를 직접 수집하여 처리하는 경우 개인정보를 처리하는 국가명

② 처리방침의 공개 의무

개인정보처리자가 개인정보 처리방침을 수립하거나 변경하는 경우에는 정보주체가 쉽게 확인할 수 있도록 대통령령으로 정하는 방법에 따라 공개하여야 한다.

령 제 31 조(개인정보 처리방침의 내용 및 공개방법 등)

② 개인정보처리자는 수립하거나 변경한 개인정보 처리방침을 개인정보처리자의 인터넷 홈페이지에 지속적으로 게재하여야 한다.

③ 인터넷 홈페이지에 게재할 수 없는 경우에는 다음 각 호의 어느 하나 이상의 방법으로 개인정보 처리방침을 공개하여야 한다.

1. 개인정보처리자의 사업장등의 보기 쉬운 장소에 게시하는 방법
2. 관보나 신문에 실는 방법
3. 간행물·소식지·홍보지 또는 청구서 등에 지속적으로 실는 방법
4. 계약서 등에 실어 정보주체에게 발급하는 방법

법 제 30 조의 2(개인정보 처리방침의 평가 및 개선권고)

① 평가 및 개선권고

보호위원회는 개인정보 처리방침에 관하여 다음 각 호의 사항을 평가하고, 평가 결과 개선이 필요하다고 인정하는 경우에는 개인정보처리자에게 개선을 권고할 수 있다.

1. 이 법에 따라 개인정보 처리방침에 포함하여야 할 사항을 적정하게 정하고 있는지 여부
2. 개인정보 처리방침을 알기 쉽게 작성하였는지 여부
3. 개인정보 처리방침을 정보주체가 쉽게 확인할 수 있는 방법으로 공개하고 있는지 여부

② 세부 절차

개인정보 처리방침의 평가 대상, 기준 및 절차 등에 필요한 사항은 대통령령으로 정한다.

령 제 31 조의 2(개인정보 처리방침의 평가 대상 및 절차)

① 보호위원회는 다음 각 호의 사항을 종합적으로 고려하여 평가 대상을 선정한다.

1. 개인정보처리자의 유형 및 매출액 규모
2. 민감정보 및 고유식별정보 등 처리하는 개인정보의 유형 및 규모
3. 개인정보 처리의 법적 근거 및 방식
4. 법 위반행위 발생 여부
5. 아동·청소년 등 정보주체의 특성

법 제 31 조(개인정보 보호책임자의 지정 등)

① 지정 의무

개인정보처리자는 개인정보의 처리에 관한 업무를 총괄해서 책임질 개인정보 보호책임자를 지정하여야 한다. 다만, 종업원 수, 매출액 등이 대통령령으로 정하는 기준에 해당하는 개인정보처리자의 경우에는 지정하지 아니할 수 있다.

령 제 32 조(개인정보 보호책임자의 업무 및 지정요건 등)

① “종업원 수, 매출액 등이 대통령령으로 정하는 기준에 해당하는 개인정보처리자”란 소상공인에 해당하는 개인정보처리자를 말한다.

② 미지정 시 책임자

개인정보 보호책임자를 지정하지 아니하는 경우에는 개인정보처리자의 사업주 또는 대표자가 개인정보 보호책임자가 된다.

③ 보호책임자의 업무

개인정보 보호책임자는 다음 각 호의 업무를 수행한다.

1. 개인정보 보호 계획의 수립 및 시행
2. 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선
3. 개인정보 처리와 관련한 불만의 처리 및 피해 구제
4. 개인정보 유출 및 오용·남용 방지를 위한 내부통제시스템의 구축
5. 개인정보 보호 교육 계획의 수립 및 시행
6. 개인정보파일의 보호 및 관리·감독
7. 그 밖에 개인정보의 적절한 처리를 위하여 대통령령으로 정한 업무

⑥ 독립성 보장

개인정보처리자는 개인정보 보호책임자가 업무를 수행함에 있어서 정당한 이유 없이 불이익을 주거나 받게 하여서는 아니 되며, 개인정보 보호책임자가 업무를 독립적으로 수행할 수 있도록 보장하여야 한다.

령 제 32 조(개인정보 보호책임자의 업무 및 지정요건 등)

⑥ 개인정보 보호책임자의 독립성 보장을 위해 다음 각 호의 사항을 준수해야 한다.

1. 개인정보 처리와 관련된 정보에 대한 개인정보 보호책임자의 접근 보장
2. 개인정보 보호책임자가 정기적으로 대표자 또는 이사회에 직접 보고할 수 있는 체계의 구축
3. 개인정보 보호책임자의 업무 수행에 적합한 조직체계의 마련 및 인적·물적 자원의 제공

법 제 31 조의 2(국내대리인의 지정)

① 지정 의무

국내에 주소 또는 영업소가 없는 개인정보처리자로서 매출액, 개인정보의 보유 규모 등을 고려하여 대통령령으로 정하는 자는 다음 각 호의 사항을 대리하는 자(이하 "국내대리인"이라 한다)를 지정하여야 한다.

1. 개인정보 보호책임자의 업무
2. 개인정보 유출 등의 통지 및 신고
3. 물품·서류 등 자료의 제출

령 제 32 조의 3(국내대리인 지정 대상자의 범위)

① 법 제 31 조의 2 제 1 항 각 호 외의 부분 전단에서 "대통령령으로 정하는 자"란 다음 각 호의 어느 하나에 해당하는 자를 말한다.

1. 전년도 전체 매출액이 1 조원 이상인 자
2. 전년도 말 기준 직전 3 개월 간 그 개인정보가 저장·관리되고 있는 국내 정보주체의 수가 일일평균 100 만명 이상인 자
3. 관계 물품·서류 등 자료의 제출을 요구받은 자로서 국내대리인을 지정할 필요가 있다고 보호위원회가 심의·의결한 자

④ 위반 시 책임

국내대리인이 제 1 항 각 호와 관련하여 이 법을 위반한 경우에는 개인정보처리자가 그 행위를 한 것으로 본다.

법 제 32 조(개인정보파일의 등록 및 공개)

① 공공기관의 등록 의무

공공기관의 장이 개인정보파일을 운용하는 경우에는 다음 각 호의 사항을 보호위원회에 등록하여야 한다.

1. 개인정보파일의 명칭
2. 개인정보파일의 운영 근거 및 목적
3. 개인정보파일에 기록되는 개인정보의 항목
4. 개인정보의 처리방법
5. 개인정보의 보유기간
6. 개인정보를 통상적 또는 반복적으로 제공하는 경우에는 그 제공받는 자
7. 그 밖에 대통령령으로 정하는 사항
8. 시행령 추가

② 등록 제외 대상

다음 각 호의 어느 하나에 해당하는 개인정보파일에 대하여는 제 1 항을 적용하지 아니한다.

1. 국가 안전, 외교상 비밀, 그 밖에 국가의 중대한 이익에 관한 사항을 기록한 개인정보파일
2. 범죄의 수사, 공소의 제기 및 유지, 형 및 감호의 집행, 교정처분, 보호처분, 보안관찰처분과 출입국관리에 관한 사항을 기록한 개인정보파일
3. 「조세범처벌법」에 따른 범칙행위 조사 및 「관세법」에 따른 범칙행위 조사에 관한 사항을 기록한 개인정보파일
4. 일회적으로 운영되는 파일 등 지속적으로 관리할 필요성이 낮다고 인정되어 대통령령으로 정하는 개인정보파일
5. 다른 법령에 따라 비밀로 분류된 개인정보파일

법 제 32 조의 2(개인정보 보호 인증)

① 인증 제도

보호위원회는 개인정보처리자의 개인정보 처리 및 보호와 관련한 일련의 조치가 이 법에 부합하는지 등에 관하여 인증할 수 있다.

② 유효기간

제 1 항에 따른 인증의 유효기간은 3 년으로 한다.

③ 인증 취소

보호위원회는 다음 각 호의 어느 하나에 해당하는 경우에는 인증을 취소할 수 있다.

1. 거짓이나 그 밖의 부정한 방법으로 개인정보 보호 인증을 받은 경우
2. 제 4 항에 따른 사후관리를 거부 또는 방해한 경우
3. 제 8 항에 따른 인증기준에 미달하게 된 경우
4. 개인정보 보호 관련 법령을 위반하고 그 위반사유가 중대한 경우

법 제 33 조(개인정보 영향평가)

① 영향평가 실시

공공기관의 장은 대통령령으로 정하는 기준에 해당하는 개인정보파일의 운용으로 인하여 정보주체의 개인정보 침해가 우려되는 경우에는 그 위험요인의 분석과 개선 사항 도출을 위한 평가(이하 “영향평가”라 한다)를 하고 그 결과를 보호위원회에 제출하여야 한다.

령 제 35 조(개인정보 영향평가의 대상)

법 제 33 조제 1 항에서 “대통령령으로 정하는 기준에 해당하는 개인정보파일”이란 다음 각 호의 어느 하나에 해당하는 개인정보파일을 말한다.

1. 구축·운용 또는 변경하려는 개인정보파일로서 5 만명 이상의 정보주체에 관한 민감정보 또는 고유식별정보의 처리가 수반되는 개인정보파일
2. 연계 결과 50 만명 이상의 정보주체에 관한 개인정보가 포함되는 개인정보파일
3. 구축·운용 또는 변경하려는 개인정보파일로서 100 만명 이상의 정보주체에 관한 개인정보파일

② 평가기관 의뢰

보호위원회는 대통령령으로 정하는 인력·설비 및 그 밖에 필요한 요건을 갖춘 자를 영향평가를 수행하는 기관(이하 “평가기관”이라 한다)으로 지정할 수 있으며, 공공기관의 장은 영향평가를 평가기관에 의뢰하여야 한다.

개인정보 영향평가 수행안내서

개인정보 영향평가의 개념

- 개인정보 영향평가(PIA, Privacy Impact Assessment)는 개인정보를 활용하는 새로운 정보시스템의 도입 및 기존 정보시스템의 중요한 변경 시, 시스템의 구축·운영·변경 등이 개인의 사생활에 미칠 영향(위험)을 미리 조사·분석·평가하고 개선 방안을

도출하는 체계적인 절차를 말한다.

법 제 34 조(개인정보 유출 등의 통지 · 신고)

① 정보주체에 대한 통지

개인정보처리자는 개인정보가 분실 · 도난 · 유출(이하 이 조에서 “유출등”이라 한다)되었음을 알게 되었을 때에는 지체 없이 해당 정보주체에게 다음 각 호의 사항을 알려야 한다.

1. 유출등이 된 개인정보의 항목
2. 유출등이 된 시점과 그 경위
3. 유출등으로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보
4. 개인정보처리자의 대응조치 및 피해 구제절차
5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처

령 제 39 조(개인정보 유출 등의 통지)

① 개인정보처리자는 개인정보가 유출 등이 되었음을 알게 되었을 때에는 서면등의 방법으로 72 시간 이내에 법 제 34 조제 1 항 각 호의 사항을 정보주체에게 알려야 한다.

③ 보호위원회 등에 대한 신고

개인정보처리자는 개인정보의 유출등이 있음을 알게 되었을 때에는 개인정보의 유형, 유출등의 경로 및 규모 등을 고려하여 대통령령으로 정하는 바에 따라 제 1 항 각 호의 사항을 지체 없이 보호위원회 또는 대통령령으로 정하는 전문기관에 신고하여야 한다.

령 제 40 조(개인정보 유출 등의 신고)

① 개인정보처리자는 다음 각 호의 어느 하나에 해당하는 경우로서 개인정보가 유출등이 되었음을 알게 되었을 때에는 72 시간 이내에 보호위원회 또는 전문기관에 신고해야 한다.

1. 1 천명 이상의 정보주체에 관한 개인정보가 유출등이 된 경우
2. 민감정보 또는 고유식별정보가 유출등이 된 경우
3. 개인정보처리시스템 또는 개인정보취급자가 개인정보 처리에 이용하는

정보기기에 대한 외부로부터의 불법적인 접근에 의해 개인정보가 유출등이 된
경우

표준 개인정보 보호지침

지침 제 34 조(개인정보 유출등의 통지 및 신고)

- '유출등을 알게 된 때'의 의미: 개인정보처리자가 유출등이 발생한 사실을 확인한 때를 의미하며, 단순히 유출등이 의심되는 정황을 인지한 시점이 아니다. 유출 가능성을 인지한 시점부터는 조사를 통해 유출 여부를 지체 없이 확인해야 한다.

법 제 34 조의 2(노출된 개인정보의 삭제 · 차단)

① 공중 노출 방지 의무

개인정보처리자는 고유식별정보, 계좌정보, 신용카드정보 등 개인정보가 정보통신망을 통하여 공중(公衆)에 노출되지 아니하도록 하여야 한다.

② 삭제·차단 조치 의무

개인정보처리자는 공중에 노출된 개인정보에 대하여 보호위원회 또는 대통령령으로 지정한 전문기관의 요청이 있는 경우에는 해당 정보를 삭제하거나 차단하는 등 필요한 조치를 하여야 한다.

령 제 40 조의 2(노출된 개인정보의 삭제 · 차단 요청 기관)

법 제 34 조의 2 제 2 항에서 “대통령령으로 지정한 전문기관”이란
한국인터넷진흥원을 말한다.